

Block 12: runtime trust and Hive/Zcash carryforward, final audit

Date: 2026-09-29. Auditor: Claude (Opus 5.5 and Sonnet 5.5). Isolated checkout: /private/tmp/kk715-b12, branch audit/715-block12-20260929, fork draft PR #889. Base: 62c6150f5, the completed Block 11 tip (PR #877 head, tree equal to unit 11i). Historical PR #842 (head 19b2283515647e21178de315ae6e09d00c66bf84) is unchanged and has no reviews. The exact final head and its hosted run are recorded in PR #889, because a report committed at a head cannot name that head.

1. Scope and provenance

Four commits carried from the agent-3 preparation packet, applied cleanly on the Block 11 tip: cfc17809d (scope freeze), 29aea4bc5 (Hive and Zcash carryforward), 499bb47d4 (malformed chain IDs) and 21909b29c (input validation, custom-domain disclosure, waiver removal). The 16 paths that differ from the agent-3 candidate a6a832a26 are exactly Block 11's own later changes; no Block 12 path drifted. The Hive, report and CI paths equal the candidate. Both blocks' edits survive in the two shared files: storage.c keeps Block 11d's lock clearing and Block 12's Orchard progress wrapper, and ci.yml keeps Block 11b's change and no longer lists hive-release-review.

Scope: the three supported Hive signing operations (transfer, account create, account update); the Zcash interactive Orchard progress wrapper; the Ethereum digest scratch wipe; and the report gate that requires six native and five dedicated wire Hive identities. No new operation family, trust root, storage format or dependency pin. The runtime trust lock (AdvancedMode and session clear revoking providers) is inherited unchanged and not modified by this delta. The agent-3 preparation record, 715-12-preparation-20260928.md, remains historical evidence for the carried commits.

2. Audit round

Two independent read-only source audits covered the full diff. The Hive signing code (consent against signed bytes, validation order, worst-case serializer sizes 505/220/190 against a 512-byte buffer, Graphene wire format, canonical signatures, key derivation, cancellation and retry) had no serious or moderate defect. The defects were in the evidence gates:

Finding	Repair	Evidence
tools/check_pallas_api_boundary.py was referenced nowhere, so it constrained no merge	Runs in the ARM build job after submodules are initialised (cd663c674)	Hosted: step succeeded on both ARM variants. Local mutation (interactive derivation stops calling the progress wrapper) fails with the exact violation
The report gate collected passing Hive identities in a set, so a duplicate (pass beside a skip) satisfied it	Each owned Hive identity must appear exactly once and pass (cd663c674)	New test fails on the previous gate (report-gate-old-control.log) and passes on the new
scripts/tests/test_hive_chain_id.py was wired into nothing	Removed. The wired test _stack12_regression.s.py covers the same cases, including the 0..31 byte sweep for every operation and omitted equals explicit mainnet	Stack12 identities pass hosted (5 of 5)

Finding	Repair	Evidence
Account create and update were compared only with the device's own output	Two native tests assemble the Graphene bytes independently with four distinct keys, names up to 16 bytes and fees 0, 1, INT64_MAX and the 3000 default, and verify the signature over the mainnet-domain digest (77f59df11). Both are required by the report gate	Six native Hive tests pass locally and hosted. Swapping owner and active in the serializer fails the create test (hive-native-swap-control.log)
Secret scan flagged three evidence lines (first hosted run failed at Stage 1)	Exact-line entries in .gitleaksignore, git-mode and no-git (a2b1cdef0)	The lines are a SHA-256 of a public source file and two public dependency commit IDs. Local gitleaks reports zero findings in tracked paths

Deliberately unchanged: `ref_block_num` is masked to its low 16 bits (documented compatibility, callers pass the full block number); `hive_signTx` does not wipe a buffer that holds only public bytes; the Ethereum hash wipe covers the enforcement-failure exit only, and the digest is public. The report waiver for `hive-release-review` remains removable through the base ledger at 62c6150f5, which still lists it as authority; the dedicated stack12 wire suite is not waivable.

3. Verification

Check	Result
Hosted run 36525612576 at 77f59df11	Failed at the secret-scan gate on three evidence lines, so every downstream job was skipped. Not a code failure
Hosted run 36526014901 at a2b1cdef0	Passed every required job, publishing skipped
Native firmware	718 full, 179 Bitcoin-only; board 28 and crypto 18 in each variant, in both harnesses
Hive native identities	6 of 6 pass in the full build; none exist in Bitcoin-only
Hive wire	5 dedicated stack12 identities pass; broad suite 11 pass and 27 unsupported-operation skips
ARM	Both variants build and pass the SRAM gate; 23 files each, hashes match the manifests
Skips	84 declared before, 76 now: the eight formerly waived <code>hive-release-review</code> wire tests run and pass
Aggregate	1,587 pass, 76 skip, 0 fail; Python pin 05c77c948d61c2a6a23aaf961ad7c45037ac739b
Static analysis	Hosted cppcheck passed. Local Docker is unresponsive, so it did not run locally
Local	clang-format 20, whitespace, submodule pins, CMake membership, report tests (20) and workflow lint pass in preflight

Artifacts were downloaded and verified against the exact head: run, head and Python pin identity, PDF and merged JUnit hashes, native identities and ARM manifests. Wrong-head and tampered-PDF controls reject. Evidence archive 715-12-final-controls-20260929.tgz binds the local logs, mutation controls and the hosted verification output.

Copilot round 1 (review 5348372225 on b173f1ad2, exact-head run 36527611348 passed) raised three findings, none about behaviour, so under the SOP severity rule the round passes: (1) this report's scope line said four native Hive identities where the gate and section 3 say six, a stale count after the two account tests were added; (2) missing spaces in a carried historical worklog sentence; (3) a memo-capacity comment left on `hive_transferAsset()` after the constant moved to the header. All three are fixed: the count is six, the worklog spacing is corrected (the file is not hash-bound by any evidence), and the capacity rationale now sits beside `HIVE_MAX_MEMO_LEN` with the worst-case arithmetic (63 bytes of non-memo overhead, a 2-byte length varint, 440 memo bytes, 505 total). The `hive.c` and `hive.h` edits are comments only; the exact final head and its hosted run are in PR #889.

4. Not claimed

Physical-device display fidelity and actual power-cycle behaviour remain release gates; debuglink text is not a substitute. The Pallas checker enforces source boundaries only, not timing or a formal constant-time property, and it matches tokens rather than parsing code. Blockchain acceptance beyond the signing invariants is not claimed. No merge or release acceptance is claimed, and no Copilot review is claimed by this document.

5. Adjacent inventory

Inventory base: 62c6150f5. Reproduce with `git diff --numstat BASE..FINAL_PR_HEAD` after the report, PDF and archive are committed.

Added	Deleted	Path
6	1	.github/workflows/ci.yml
12	0	.gitleaksignore
17	1	include/keepkey/firmware/hive.h
1	0	lib/firmware/ethereum.c
75	25	lib/firmware/fsm_msg_hive.h
96	17	lib/firmware/hive.c
11	2	lib/firmware/storage.c
7	0	scripts/emulator/python-keepkey-tests.sh
153	0	scripts/emulator/test_stack12_regressions.py
36	0	scripts/generate-test-report.py
43	0	scripts/test_generate_test_report.py
244	0	tools/check_pallas_api_boundary.py
1	0	unittests/firmware/CMakeLists.txt
367	0	unittests/firmware/hive_transfer.cpp
56	0	docs/release/audit-units/715-12-agent3-intake-20260928.json
77	0	docs/release/audit-units/715-12-final-audit-20260929.md
-	-	docs/release/audit-units/715-12-final-audit-20260929.pdf

Added	Deleted	Path
-	-	docs/release/audit-units/715-12-final-controls-20260929.tgz
39	0	docs/release/audit-units/715-12-first-checks-20260927.json
100	0	docs/release/audit-units/715-12-intake-20260927.json
85	0	docs/release/audit-units/715-12-resume-20260927.md
63	0	docs/release/audit-units/715-12-resume-evidence-20260927.json
-	-	docs/release/audit-units/715-12-resume-raw-20260927.tar.gz
31	0	docs/release/audit-units/715-12-worklog-20260927.md